

Security in the Data Lifecycle

Classification, statuses, roles, and information flow control

FDSI



Data is one of the most valuable assets of any organization. Protecting it is not only a technical issue, but also an organizational and legal responsibility. Throughout this presentation, we will explore how information is classified, what states it can be in, who is responsible for its care, and how its entire life cycle is controlled.





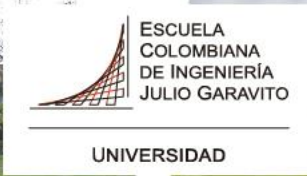
What is the data lifecycle?

- Data does not come into being and die in the same instant. From the moment it is created until it is securely deleted, it goes through multiple stages that require different controls. This journey is known as the data lifecycle and comprises the following phases:
 - **Creation/Capture:** the data is generated or collected (forms, sensors, transactions).



- **Storage:** the data is stored in databases, servers, or the cloud.
- **Use/Processing:** the data is consulted, modified, or analyzed.
- **Transmission/Transit:** the data is moved from one system to another.
- **Archiving:** the data is retained for legal or historical reasons.
- **Destruction:** the data is securely deleted when it is no longer needed.





- **1. Creation / Capture**

The data is generated or collected.

Examples:

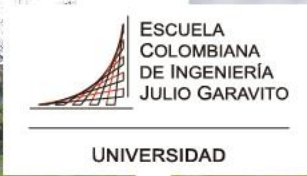
- A user fills out a **registration form** on a website with their name and email.
- A **temperature sensor** in a factory records 25 °C.
- An **online purchase** generates data such as product, price, and date.
- A student fills out a **university enrollment form**.

- **2. Storage**

The data is saved so it can be used later.

Examples:

- User information is stored in a **PostgreSQL database**.
- Photos uploaded by users are stored on a **server or cloud storage**.
- Sales records are stored in the **company's accounting system**.



- **3. Use / Processing**

The data is consulted, analyzed, or modified.

Examples:

- A system calculates the **total cost of a purchase** using stored prices.
- An analyst reviews **monthly sales data** to generate a report.
- An application displays a **user profile** when someone logs in.

- **4. Transmission / Transit**

Data moves from one system or device to another.

Examples:

- When you log in, your **username and password** are sent from the browser to the **server**.
- A payment system sends **transaction data to the bank**.
- A microservice sends **order information to another service through an API**.



- **5. Archiving**

Data is stored long-term for legal or historical reasons.

Examples:

- A company keeps **invoices from the last 5 years** due to legal requirements.
- A university archives **academic records of graduated students**.
- A hospital stores **old medical records**.

- **6. Destruction**

Data is securely deleted when it is no longer needed.

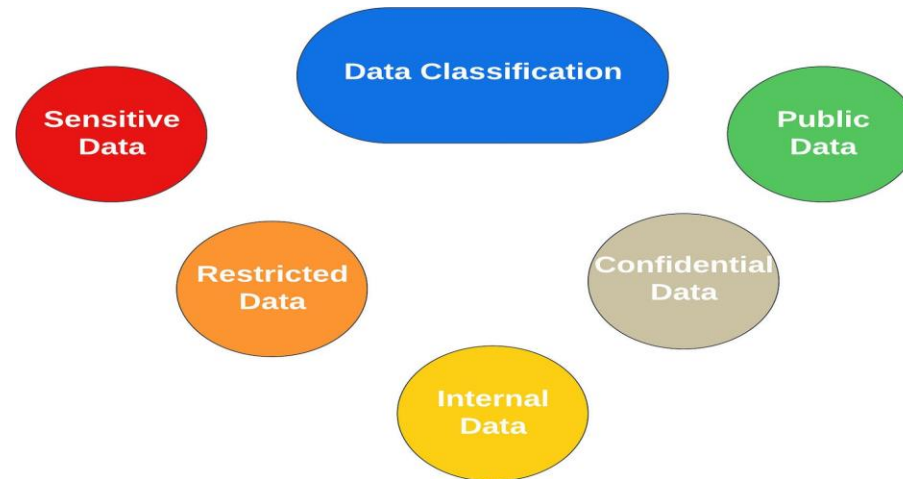
Examples:

- A company deletes **inactive user accounts after several years**.
- Old files are **permanently deleted or overwritten** to prevent recovery.
- Personal data is removed when a user requests the **right to be forgotten**.

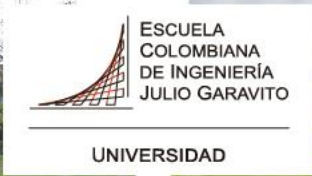


Why classify data?

- Classifying data means assigning it a category based on its level of sensitivity and the impact that its loss, theft, or disclosure would have. This classification is the first step in applying appropriate security controls.



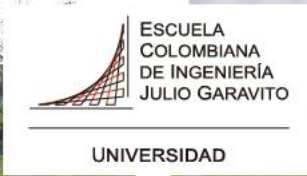
- *Why is it important?*
 - It allows security resources to be focused where they are most needed.
 - It facilitates compliance with legal regulations (such as data protection laws).
 - It reduces the risk of accidentally exposing sensitive information.
 - It helps define who can access what information and under what conditions.



Data classification levels

- Although the exact levels vary depending on the organization or government, a common classification scheme is as follows:

Level	Description	Example
Public	Can be shared freely without risk	Press Releases, Websites
Internal	For use within the organization only	Internal manuals, corporate policies
Confidential	Restricted access, moderate damage if filtered	Contracts, customer data
Secret / Critical	Serious harm if disclosed; Maximum protection	Financial data, health information, credentials



Criteria for classifying a piece of data:

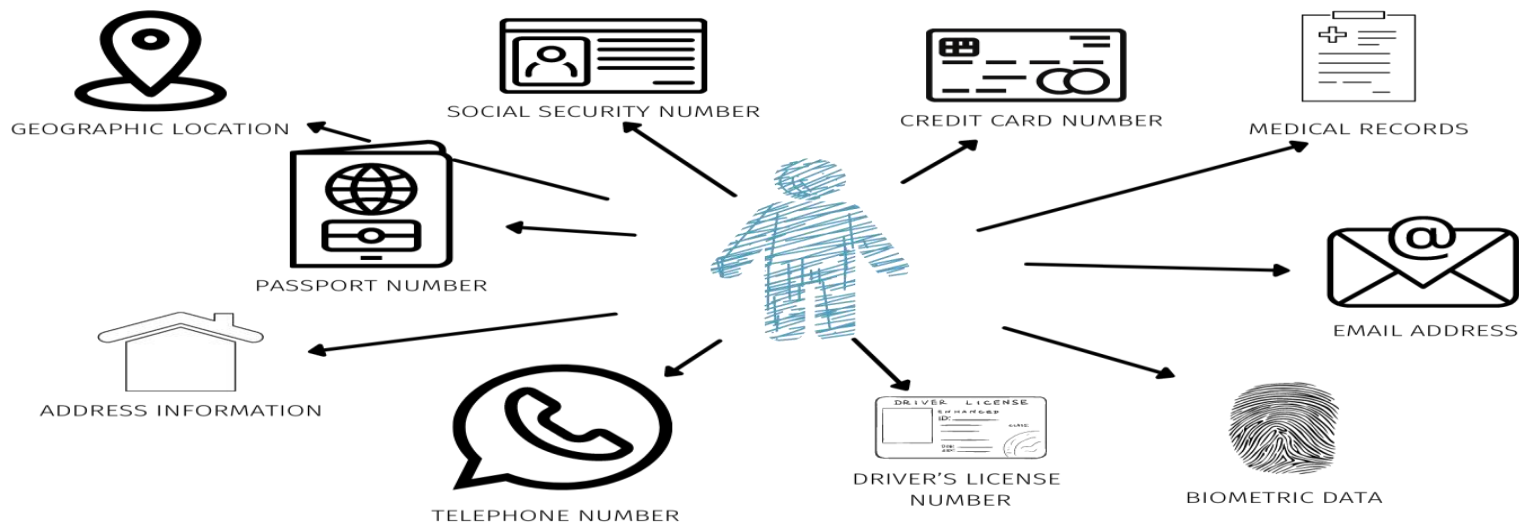
- **Confidentiality:**
 - How sensitive is it?
- **Integrity:**
 - How serious would it be if it were modified without authorization?
- **Availability:**
 - How critical is it that it is always accessible?





Personal Data and PII

- PII (Personally Identifiable Information) is any data that allows a person to be identified, either directly or indirectly.
- Examples of PII:
 - Full name, identification number, date of birth.
 - Email address, phone number.
 - Medical, financial, or biometric information.
 - IP address, browsing cookies, GPS location.



Why does it deserve special attention?

- Because its exposure can cause real harm to real people: identity theft, discrimination, financial loss, or damage to reputation.
- Organizations that handle PII must apply special privacy controls and, in many countries, comply with specific laws (such as the GDPR in Europe or Law 1581 in Colombia).



The three states of data

- Data is not always in the same place or in the same condition. Depending on where and how it is found, we refer to three states, each of which requires different protection mechanisms:

THE THREE STATES OF DATA

AT REST



IN TRANSIT



IN USE



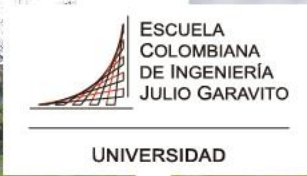


1. Data at Rest

- The data is stored and is not actively moving or being used.
 - Examples: files on a hard drive, databases, backups.
 - Main risk: unauthorized physical or logical access to storage.

2. Data in Transit

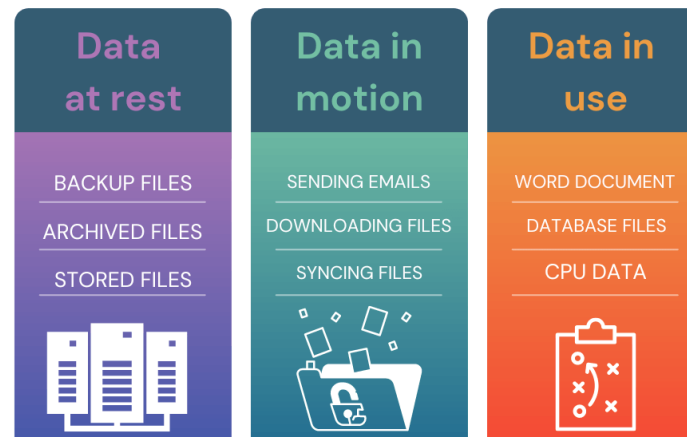
- The data is being moved from one system to another via a network.
 - Examples: emails, file transfers, connections to websites.
 - Main risk: interception (man-in-the-middle attacks).



3. Data in Use

- The data is being actively processed by an application or user.
 - Examples: data opened in a browser, processed in RAM, displayed on screen.
 - Main risk: unauthorized access to memory or active session.

States of Data





Protecting data at rest

Just because data is “stored” does not mean it is secure. The main mechanisms for protecting data at rest are:

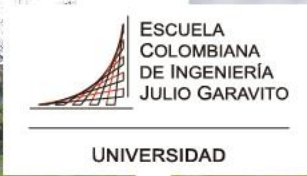
- Storage encryption: converting data into unreadable text that can only be decrypted with a key. Example: AES-256 encryption. Access control: defining who can read, write, or delete files.
- Access control lists (ACLs) and least privilege policies are applied.
- Secure backups: backup copies stored in encrypted form and in separate locations.
- File integrity: tools that detect unauthorized changes to stored files (cryptographic hashes).
- Sanitization upon deletion: when data is deleted, it must be removed in such a way that it cannot be recovered.



Data protection in transit

When data travels over a network, it can be intercepted if it is not properly protected. Key measures include:

- TLS/SSL (Transport Layer Security): a protocol that encrypts communications between client and server. This is what makes a website use “https://”.
- VPN (Virtual Private Network): creates an encrypted tunnel over public networks, protecting it from the outside.
- Mutual authentication: both the client and the server verify each other before exchanging data.
- Digital signatures: ensure that the data was not altered during transit (integrity).
- Avoid untrusted networks: do not transmit sensitive data over public Wi-Fi without additional encryption.



Data protection in use

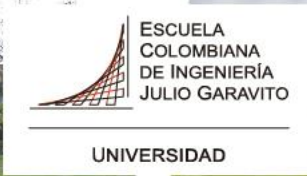
Data in use is the most difficult to protect because, in order to be processed, it must be “decrypted” and accessible. The threats are diverse:

- Memory attacks: malware that extracts data directly from RAM.
- Screen capture or keyloggers: malicious software that records what the user types or sees.
- Physical access: someone looking at the user's screen (shoulder surfing).
- Recommended controls:
 - Confidential Computing: technology that encrypts data even while it is being processed.
 - Sessions with automatic expiration times.
 - Multi-factor authentication (MFA) for accessing critical systems.
 - Clean screen and clean desktop policies.



Roles in data management

- It is not enough to have protection technology. It must be clear who is responsible for each piece of data. According to DAMA International (DMBOK2) and NIST guidelines, there are three essential roles:
 - 1. Data Owner
 - 2. Data Custodian
 - 3. Data User



1. Data Owner

- This is the person or business area that has ultimate responsibility for a set of data. They define the classification level of the data and who can access it.

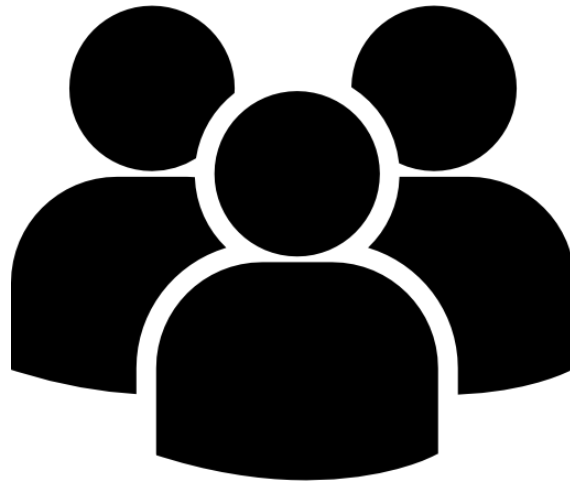
2. Data Custodian

- This is the person who technically manages the data: stores it, backs it up, and applies the security controls defined by the owner. This is usually the IT department.



3. Data User

- This is the person who accesses and uses the data to perform their work or academic duties. They must comply with usage policies and not share the data without authorization.





Identity-based access control

For roles to work in practice, a robust identity management system is required. The guiding principle is least privilege: each user should only have access to the data strictly necessary to perform their role.

- Access control models:
 - DAC (Discretionary Access Control): the owner decides who has access.
 - MAC (Mandatory Access Control): the system assigns access according to classification levels.
 - RBAC (Role-Based Access Control): access is defined according to the user's role in the organization. This is the most common model in companies.
 - ABAC (Attribute-Based Access Control): access depends on multiple attributes (role, time, location, device).



Authentication vs. Authorization:

- Authentication: verifying that you are who you say you are (password, fingerprint, MFA).
- Authorization: verifying what you can do once you have logged in.

Authentication



Confirms users
are who they say they are.

Authorization



Gives users permission
to access a resource.



Data Retention

- Data retention is the policy that defines how long data should be kept before being deleted or archived. It is not an arbitrary decision: it is guided by law, business, and security.





Why is it important to retain data for the right amount of time?

- Too little time: information needed for audits, litigation, or legal compliance may be lost.
- Too long: unnecessary information accumulates, increasing the risk in the event of a security breach.

Factors that determine the retention period:

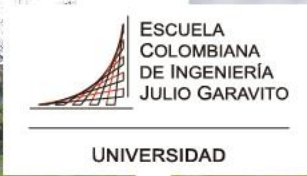
- Legal and regulatory requirements (example: accounting records may require 5-10 years).
- Operational value of the data for the organization.
- Type of data (medical, financial, human resources, etc.).
- Assigned classification level.



Secure data destruction

- When data reaches the end of its useful life, simply deleting it from the recycle bin is not enough. Data can be recovered using specialized tools if it is not destroyed properly.





- **Sanitization methods according to NIST SP 800-88:**

- Logical erasure (Clear): overwrite the data with zeros or random data. Valid for media that will remain in use.
- Purge: more advanced techniques that delete data so that it cannot be recovered even by a forensic laboratory. Example: degaussing.
- Physical destruction: shredding, melting, or disintegrating the storage medium. Applicable when the hardware will not be used again.

- **Practical importance:**

- Decommissioned hard drives that have not been sanitized have been sold on second-hand markets with complete corporate data.
- Printers and photocopiers also store copies of documents in their internal memory.



Data flow control

- Data flow control consists of monitoring and regulating how information moves in and out of the organization. It ensures that data only goes where it should go.
- **Flow control tools and techniques:**
 - DLP (Data Loss Prevention): systems that detect and block unauthorized transmissions of sensitive data (by email, USB, printing, etc.).
 - Automatic classification and labeling: data is labeled when it is created and the system automatically applies rules based on that label.
 - Audit logs: all access, modification, or movement of data is logged for later review.
 - Network segmentation: limiting which systems can communicate with each other reduces the risk of sensitive data leaving protected areas.
 - Mobile device management (MDM): control over what data can be stored on personal or mobile devices.



Regulatory frameworks of reference

- Data lifecycle security is not an opinion – it is backed by recognized international standards.

Standard	Organization	Main contribution
NIST SP 800-53 Rev.5	NIST	Security and privacy controls for information systems
NIST SP 800-60 Rev.1	NIST	Information and Systems Classification
NIST SP 800-122	NIST	Protection of Personal Information (PII)
NIST SP 800-63-3	NIST	Digital Identity Management
NIST SP 800-57	NIST	Cryptographic Key Management
NIST SP 800-88 Rev.1	NIST	Sanitization of storage media
NIST CSF 2.0	NIST	Comprehensive Cybersecurity Framework
ISO/IEC 27001	ISO	Information Security Management System
DAMA-DMBOK2	DAMA International	Data governance and management
CSA v4.0	Cloud Security Alliance	Security in cloud environments



References

- NIST SP 800-53 Rev.5 → <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf>
- NIST SP 800-60 Rev.1 → <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-60v1r1.pdf>
- NIST SP 800-122 → <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-122.pdf>
- NIST SP 800-63-3 → <https://pages.nist.gov/800-63-3/>
- NIST SP 800-57 Pt.1 Rev.5 → <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-57pt1r5.pdf>
- NIST SP 800-88 Rev.1 → <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-88r1.pdf>
- NIST Cybersecurity Framework 2.0 → <https://www.nist.gov/cyberframework>
- ISO/IEC 27001 → <https://www.iso.org/isoiec-27001-information-security.html>
- DAMA-DMBOK2 → <https://www.dama.org/cpages/body-of-knowledge>
- Cloud Security Alliance v4.0 → <https://cloudsecurityalliance.org/artifacts/security-guidance-v4/>

Gracias